

REPORTE EJECUTIVO DE RIESGOS

Clínica privada ficticia de 120 empleados y aproximadamente 800 pacientes por día.

RESUMEN EJECUTIVO

El registro inicial identificó siete riesgos prioritarios. La matriz académica de probabilidad por impacto clasifica tres como críticos y cuatro como altos. En la escala nativa Classic de SimpleRisk, ransomware, falla de infraestructura y equipos médicos desactualizados obtuvieron la mayor puntuación: 8, nivel High. Los tres cuentan con mitigaciones planificadas.

TOP 5 DE RIESGOS

1. Ransomware sobre historias clínicas y admisión. Valor académico 20, crítico; SimpleRisk 8, High. Puede interrumpir la atención y exponer información clínica.
2. Falla de infraestructura clínica. Valor académico 20, crítico; SimpleRisk 8, High. Puede dejar sin historias clínicas, turnos y facturación.
3. Robo de credenciales mediante phishing. Valor académico 16, crítico; SimpleRisk 6,4, Medium. Puede habilitar fraude, acceso indebido y movimiento lateral.
4. Acceso interno indebido a historias clínicas. Valor académico 15, alto; SimpleRisk 6, Medium. Puede producir daño personal, legal y reputacional.
5. Brecha de un proveedor. Valor académico 15, alto; SimpleRisk 6, Medium. Puede exponer datos intercambiados con obras sociales y otros terceros.

Las escalas no son equivalentes. La matriz de 1 a 5 responde a la consigna académica; SimpleRisk muestra su cálculo nativo Classic.

Review Regularly

Below is the list of all risks sorted by Unreviewed, Past Due, and Next Review Date.

10 entries per page

ID	Status	Subject	Inherent Risk (Current)	Days Open	Next Review Date
ID	Status	Subject	Inherent Risk (C	Days Open	Next Review Date
1002	New	Ransomware cifra sistemas clínicos y estaciones de admisión	8	0	UNREVIEWED
1005	New	Falla de infraestructura interrumpe servicios clínicos	8	0	UNREVIEWED
1008	New	Equipos médicos desactualizados comprometen la red clínica	8	0	UNREVIEWED
1001	New	Interrupción del sistema de historias clínicas	6.4	0	UNREVIEWED
1003	New	Robo de credenciales mediante phishing	6.4	0	UNREVIEWED
1004	New	Acceso interno indebido a historias clínicas	6	0	UNREVIEWED
1006	New	Brecha de un proveedor expone datos de pacientes	6	0	UNREVIEWED
1007	New	Alteración de códigos produce facturación incorrecta	4.8	0	UNREVIEWED

Showing 1 to 8 of 8 entries

First

Previous

1

Next

Last

Show All

Evidencia 1. Riesgo de prueba R-01 y siete riesgos del caso R-02 a R-08 registrados en SimpleRisk.

ESTADO DE LOS PLANES DE ACCIÓN

Plan 1. Protección y recuperación ante ransomware. Asociado a R-02, con vencimiento el 30 de noviembre de 2026. Incluye MFA, EDR, segmentación, copias 3-2-1 aisladas e inmutables, restauración y respuesta a incidentes.

Plan 2. Continuidad de infraestructura clínica. Asociado a R-05, con vencimiento el 31 de enero de 2027. Incluye UPS dimensionada, redundancia, monitoreo, mantenimiento y prueba de continuidad.

Plan 3. Seguridad de equipos médicos. Asociado a R-08, con vencimiento el 28 de febrero de 2027. Incluye inventario, segmentación, coordinación de parches, controles compensatorios, monitoreo y aislamiento.

Los tres planes están asignados a Ana Analista, tienen un presupuesto académico estimado entre USD 0 y USD 100.000 y se encuentran en estado Mitigation Planned con avance inicial del 0 por ciento.

Review Regularly

Below is the list of all risks sorted by Unreviewed, Past Due, and Next Review Date.

10 entries per page

ID	Status	Subject	Inherent Risk (Current)	Days Open	Next Review Date
ID	Status	Subject	Inherent Risk (Current)	Days Open	Next Review Date
1002	Mitigation Planned	Ransomware cifra sistemas clínicos y estaciones de admisión	8	0	UNREVIEWED
1005	Mitigation Planned	Falla de infraestructura interrumpe servicios clínicos	8	0	UNREVIEWED
1008	Mitigation Planned	Equipos médicos desactualizados comprometen la red clínica	8	0	UNREVIEWED
1001	New	Interrupción del sistema de historias clínicas	6.4	0	UNREVIEWED
1003	New	Robo de credenciales mediante phishing	6.4	0	UNREVIEWED
1004	New	Acceso interno indebido a historias clínicas	6	0	UNREVIEWED
1006	New	Brecha de un proveedor expone datos de pacientes	6	0	UNREVIEWED
1007	New	Alteración de códigos produce facturación incorrecta	4.8	0	UNREVIEWED

Showing 1 to 8 of 8 entries

First

Previous

1

Next

Last

Show All

Evidencia 2. Vista conjunta de los riesgos y los tres registros con mitigación planificada.

Maria Paz Sinner - LU 31911682 - Comisión 4to año

Página 2

RECOMENDACIONES PRIORITARIAS

1. Aprobar responsables, plazos y presupuesto preliminar de los tres planes.
2. Priorizar MFA, EDR y una restauración documentada de las copias de seguridad.
3. Probar la continuidad manual de historias clínicas, turnos y facturación, y medir la autonomía y recuperación de la infraestructura.
4. Completar el inventario y la segmentación de equipos médicos, coordinando vulnerabilidades con los fabricantes.
5. Revisar mensualmente la cobertura de MFA y EDR, los resultados de restauración, los simulacros de continuidad y el avance de los planes.

DECISIÓN SOLICITADA

Se solicita al directorio autorizar los tres planes y establecer un seguimiento mensual basado en evidencia de implementación y eficacia. El avance debe comprobarse mediante cobertura real de controles, restauraciones exitosas, simulacros y reducción de accesos o comunicaciones innecesarias.

ENFOQUE Y LIMITACIONES

SimpleRisk se utilizó como registro operativo y se complementó con NIST SP 800-30 para explicitar amenazas, vulnerabilidades, probabilidad, impacto e incertidumbre. El escenario, los controles actuales y los presupuestos son supuestos académicos. Los valores residuales son estimaciones previas a la implementación y deben validarse con evidencia técnica, pruebas, métricas y cotizaciones.

FUENTES

NIST, SP 800-30 Rev. 1: Guide for Conducting Risk Assessments. <https://csrc.nist.gov/pubs/sp/800/30/r1/final>

U.S. HHS, Healthcare and Public Health Cybersecurity Performance Goals. <https://hhscyber.hhs.gov/cybersecurity-performance-goals.html>

SimpleRisk, documentación oficial y API Overview. <https://support.simplerisk.com/kb/08-01-api-overview>